



Rajarata University of Sri Lanka

Faculty of Applied Sciences
Department of Computing

ICT 3216 Introduction to Ethical Hacking

Group Assignment 1

Name	Register_no	Index_no
A.K.W. Ahamed	ICT/2021/003	5165
J.H.G.C. Kumari	ICT/2021/059	5219
R. G.S. Silva	ICT/2021/117	5272
O. W.W.B.M.R.P. Tanne	ICT/2021/124	5279

INTRODUCTION

Reconnaissance is the first phase of cybersecurity testing, focused on gathering information about a target system or web application before deeper analysis. It helps identify exposed services, technologies and network configurations to understand the potential attack surface. Reconnaissance can be passive (collecting public information) or active (using controlled techniques). A Bug Bounty Programme provides a legal framework that allows ethical hackers to test systems within defined boundaries.

TARGET OVERVIEW

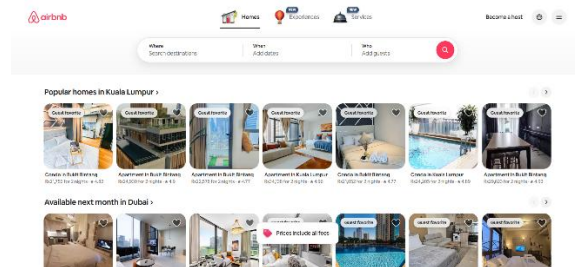
Selected Platform

The target was selected from a bug bounty platform **HackerOne**.

Selected Web Application

Target Domain: www.airbnb.com

The domain was confirmed to be listed as **in-scope** according to the program rules.



KALI LINUX ENVIRONMENT SETUP

All testing was conducted using Kali Linux installed inside a Virtual Machine.

The following commands were executed:

```
sudo apt update
```

```
sudo apt install nmap -y
```

```
sudo apt install dmidecode -y
```

To verify the use of a virtual machine, the following command was executed:

```
sudo dmidecode -s system-uuid
```

This generated a unique system UUID, confirming that testing was performed inside a Kali Linux VM.

UUID Screenshots

```
(wfy_ahamed@ahamed)-[~]
$ sudo dmidecode -s system-uuid

[sudo] password for wfy_ahamed:
7c66eb99-15de-8a4c-81dd-439f4ee53f38

(wfy_ahamed@ahamed)-[~]
$
```

Member 1

```
(gimhani@kali)-[~]
$ sudo dmidecode -s system-uuid
4948a0ca-e863-904d-b539-f7f9246c1e1a
```

Member 2

```
Session Actions Edit View Help
(gaguli@kali)-[~]
$ sudo dmidecode -s system-uuid
713ece6f-3e2e-794f-8ac1-5d8efbd4c0aa

[sudo] password for gaguli:
713ece6f-3e2e-794f-8ac1-5d8efbd4c0aa
```

Member 3

```
(poornima@kali)-[~]
$ sudo dmidecode -s system-uuid
1af99a9a-dc8b-2246-b1e4-8550c1dcc046

(poornima@kali)-[~]
$
```

Member 4

```
Session Actions Edit View Help
(wfy_ahamed@ahamed)-[~]
$ sudo apt update
[sudo] password for wfy_ahamed:
250rry, try again.
[sudo] password for wfy_ahamed:
Hit:1 http://http.kali.org/kali kali-rolling InRelease
1623 packages can be upgraded. Run 'apt list --upgradable' to see them.

(wfy_ahamed@ahamed)-[~]
$ sudo apt install nmap -y
Upgrading:
nmap nmap-common

Summary:
Upgrading: 2, Installing: 0, Removing: 0, Not Upgrading: 1621
Download size: 6,638 kB
Space needed: 947 kB / 7,795 MB available

Get:1 http://http.kali.org/kali kali-rolling/non-free amd64 nmap amd64 7.98+dfsg-1kalil1 [1,965 kB]
Get:2 http://http.kali.org/kali kali-rolling/non-free amd64 nmap-common all 7.98+dfsg-1kalil1 [4,673 kB]
Fetched 6,638 kB in 5s (1,309 kB/s)
(Reading database ... 422038 files and directories currently installed.)
Preparing to unpack .../nmap_7.98+dfsg-1kalil1_amd64.deb ...
Unpacking nmap (7.98+dfsg-1kalil1) over (7.95+dfsg-3kalil1) ...
Preparing to unpack .../nmap-common_7.98+dfsg-1kalil1_all.deb ...
Unpacking nmap-common (7.98+dfsg-1kalil1) over (7.95+dfsg-3kalil1) ...
Setting up nmap-common (7.98+dfsg-1kalil1) ...
Setting up nmap (7.98+dfsg-1kalil1) ...
Setcap worked! Adding configuration to environment
Processing triggers for kali-menu (2025.4.3) ...
Processing triggers for man-db (2.13.1-1) ...
Processing triggers for wordlists (2025.4.0) ...

(wfy_ahamed@ahamed)-[~]
$ sudo apt install dmidecode -y
dmidecode is already the newest version (3.6-2).

Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1621

(wfy_ahamed@ahamed)-[~]
$ sudo dmidecode -s system-uuid
7c66eb99-15de-8a4c-81dd-439f4ee53f38
```

Task 1: DNS RESOLUTION ANALYSIS

Command Used:

nslookup www.airbnb.com

```
(wfy_ahamed@ahamed)-[~]
$ nslookup www.airbnb.com

Server:          10.95.1.220
Address:         10.95.1.220#53

Non-authoritative answer:
www.airbnb.com canonical name = san.airbnb.com.edgekey.net.
san.airbnb.com.edgekey.net canonical name = e118243.a.akamaiedge.net.
Name:   e118243.a.akamaiedge.net
Address: 23.202.229.142
Name:   e118243.a.akamaiedge.net
Address: 23.202.229.133

(wfy_ahamed@ahamed)-[~]
```

Findings

The domain resolved to:

- Akamai Edge Network
- Multiple IP addresses belonging to Akamai infrastructure

Explanation

The presence of a CNAME record pointing to akamaiedge.net confirms that the website uses a CDN. A CDN improves:

- Performance ,Load balancing , DDoS protection ,Scalability

This indicates enterprise-level infrastructure design.

NMAP PORT SCAN

Command Used

nmap -sV -p 80,443 www.airbnb.com

Results

Port	State	Service	Version
80	Open	HTTP	AkamaiHost
443	Open	SSL/HTTP	AkamaiHost

```
(wfy_ahamed@ahamed)-[~]
$ nmap -sV -p 80,443 www.airbnb.com

Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-15 16:55 +0530
Nmap scan report for www.airbnb.com (23.202.229.133)
Host is up (0.015s latency).
Other addresses for www.airbnb.com (not scanned): 23.202.229.142
rDNS record for 23.202.229.133: a23-202-229-133.deploy.static.akamaitechnologies.com

PORT      STATE SERVICE VERSION
80/tcp    open  http    AkamaiGHost (Akamai's HTTP Acceleration/Mirror service)
443/tcp   open  ssl/http AkamaiGHost (Akamai's HTTP Acceleration/Mirror service)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.42 seconds

(wfy_ahamed@ahamed)-[~]
$
```

Technical Analysis

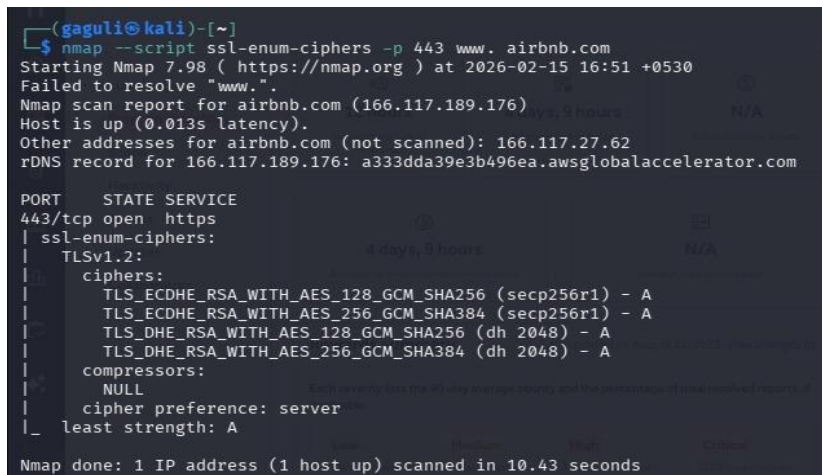
- Port 80 is used for HTTP communication.
- Port 443 is used for HTTPS encrypted communication.
- Both services are managed by Akamai.

No additional ports were exposed, indicating proper firewall configuration and minimal attack surface.

Task 2: NSE SCRIPT SCAN

Command Used

`nmap --script ssl-enum-ciphers -p 443 www.airbnb.com`



```
(gaguli@kali)-[~]
$ nmap --script ssl-enum-ciphers -p 443 www.airbnb.com
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-15 16:51 +0530
Failed to resolve "www.".
Nmap scan report for airbnb.com (166.117.189.176)
Host is up (0.013s latency).
Other addresses for airbnb.com (not scanned): 166.117.27.62
rDNS record for 166.117.189.176: a333dda39e3b496ea.awsglobalaccelerator.com

PORT      STATE SERVICE
443/tcp   open  https
| ssl-enum-ciphers:
|   TLSv1.2:
|   | ciphers:
|   |   TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (secp256r1) - A
|   |   TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (secp256r1) - A
|   |   TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (dh 2048) - A
|   |   TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (dh 2048) - A
|   | compressors:
|   |   NULL
|   | cipher preference: server
|   |_ least strength: A
Nmap done: 1 IP address (1 host up) scanned in 10.43 seconds
```

Purpose of Script

The ssl-enum-ciphers script checks:

- SSL/TLS versions supported
- Encryption cipher strength
- Weak

Security Observation

The SSL configuration uses strong encryption protocols. This ensures:

- Data confidentiality
- Secure communication
- Protection against interception attacks

Explanation of the Command:

- `-p 443` → Scans port 443 (HTTPS service)
- `--script ssl-enum-ciphers` → Enumerates supported SSL/TLS ciphers
- `www.airbnb.com` → Target domain

Host Information

- Target Domain: www.airbnb.com
- Resolved IP Address: 166.117.189.176
- Host Status: Up
- Latency: 0.013 seconds

This indicates that the server is reachable and responding normally.

Port and Service Status

Port	State	Service
443/tcp	Open	HTTPS

Port 443 is open and actively running HTTPS, which is expected for secure web communication.

Supported TLS Version

The scan shows that the server supports:

- **TLS 1.2**

Older versions such as TLS 1.0 and TLS 1.1 were not detected, which is a positive security practice since they are considered insecure.

Supported Cipher Suites

The following strong cipher suites were identified:

- TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
- TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
- TLS_DHE_RSA_WITH_AES_128_GCM_SHA256
- TLS_DHE_RSA_WITH_AES_256_GCM_SHA384

Task 3: TECHNOLOGY STACK IDENTIFICATION

The **WhatWeb** tool was used on www.airbnb.com to identify the web application's technologies and frameworks. In addition, the **Wappalyzer browser extension** was used to perform client-side technology detection. Both tools help in identifying the technology stack without exploiting the target. The analysis revealed that the web application uses Akamai as its Content Delivery Network (CDN), which provides traffic distribution, performance optimization and DDoS protection. The frontend framework detected was React, which is a JavaScript library used for building dynamic user interfaces. The presence of RequireJS indicates the use of modular JavaScript loading.

No	Technology Identified	Category	Version	Evidence (From Screenshot/Scan)	Purpose / Function
1	Akamai CDN (AkamaiGHost)	Content Delivery Network (CDN)	Not Disclosed	Akamai-Global-Host, AkamaiGHost	Improves performance, hides origin server, provides DDoS protection and WAF services
2	NGINX	Web Server	Not Disclosed	Server: nginx, HTTPServer[nginx]	Handles HTTP/HTTPS requests, reverse proxy, load balancing
3	HTTPS (TLS)	Secure Communication Protocol	Not Disclosed	Port 443 open	Encrypts communication between client and server
4	Strict-Transport-Security (HSTS)	Security Header	max-age=10886400	Strict-Transport-Security header	Forces browsers to use HTTPS only, prevents SSL stripping
5	X-Frame-Options	Security Header	SAMEORIGIN	X-Frame-Options: SAMEORIGIN	Prevents clickjacking attacks
6	X-XSS-Protection	Security Header	Enabled	X-XSS-Protection: 1; mode=block	Protects against basic reflected XSS attacks
7	Open Graph Protocol	Web Metadata Standard	Not Disclosed	Open-Graph-Protocol	Enables social media link previews
8	Cookies (_country, bev, _user_attributes)	Session Management	Not Disclosed	Set-Cookie headers	User tracking, session handling, personalization
9	HttpOnly Cookie Attribute	Cookie Security Feature	Enabled	HttpOnly flag	Prevents JavaScript access to cookies (mitigates XSS)
10	Secure Cookie Attribute	Cookie Security Feature	Enabled	Secure flag	Ensures cookies are sent only over HTTPS
11	Chunked Transfer Encoding	HTTP Feature	Enabled	Transfer-Encoding: chunked	Improves performance by sending data in chunks

Task 4: VULNERABILITY RESEARCH

This section analyzes eight common security vulnerabilities linked to the technologies identified, based on industry standards like OWASP Top 10, CWE and NIST. It highlights potential risks without implying the target is actively vulnerable, demonstrating awareness of real-world security concerns.

Assessment Scope: Technology stack vulnerabilities based on reconnaissance findings

Technologies Analyzed: CDN infrastructure (Akamai), NGINX web server, TLS/SSL implementation, HTTP security headers and cookie security mechanisms

Vulnerability Summary

The following table provides a high-level overview of the Three vulnerabilities researched, organized by criticality level

	Vulnerability	Technology	Criticality
1	CDN Misconfiguration	Akamai CDN	Medium
2	Weak NGINX Configuration	NGINX Web Server	High
3	Weak TLS Cipher Suites	TLS/SSL (Port 443)	Critical

Detailed Vulnerability Analysis

The following sections provide comprehensive analysis of each identified vulnerability, including technical description, potential impact, criticality assessment and detailed remediation guidance.

1. CDN Misconfiguration & Origin Exposure

Technology: Content Delivery Network (Akamai / similar edge services)

Vulnerability Description:

Content Delivery Networks (CDNs) provide protection and performance benefits, but misconfigurations can expose the origin server's IP via DNS, headers, SSL certificates or historical data. Attackers can then bypass CDN protections to launch direct attacks, evade WAFs, or exploit underlying vulnerabilities.

Criticality Level: Medium

Potential Impact:

- Bypass of DDoS protection mechanisms
- Circumvention of Web Application Firewall rules
- Direct attacks on origin infrastructure
- Potential service disruption or complete outage

CODE: `curl -I https://airbnb.com`

```
(gimhani@kali) ~
$ curl -I https://www.airbnb.com
HTTP/2 200
server: nginx
content-type: text/html; charset=utf-8
x-instrumentation: airbnb
x-server-lifecycle-phase: running
status: 200 OK
expires: Thu, 01 Jan 1970 00:00:00 GMT
x-kraken-loop-name: core-guest-loop
accept-ch: Sec-CH-Device-Memory, Sec-CH-DPR, ECT, Sec-CH-UA-Platform-Version, Sec-CH-Viewport-Width, Sec-CH-Device-Memory, Sec-CH-DPR, ECT, Sec-CH-UA-Platform-Version, Sec-CH-Viewport-Width
accept-ch-lifetime: 31536000
cache-control: no-store, max-age=0, private, must-revalidate
```

Figure 1: CDN identification for airbnb.com showing Akamai edge network headers obtained using an HTTP HEAD request.

2. Outdated or Weak NGINX Configuration

Technology: NGINX Web Server

Vulnerability Description:

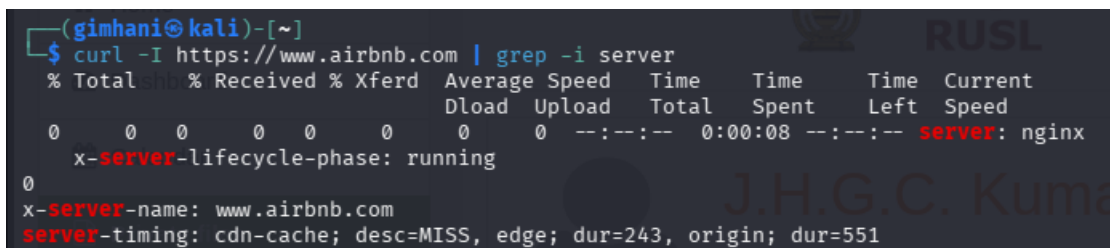
NGINX, a widely used web server and reverse proxy, can be vulnerable if misconfigured or outdated, leading to risks like HTTP request smuggling, information leaks, directory traversal and denial-of-service. Common issues include exposed server versions, insecure proxy settings, missing security headers, disabled rate limiting and unnecessary modules, all of which increase the attack surface.

Criticality Level: High

Potential Impact:

- HTTP request smuggling enabling cache poisoning and authentication bypass
- Information disclosure revealing system architecture and versions
- Denial-of-service through resource exhaustion
- Potential remote code execution through known CVEs in outdated versions

`curl -I https://airbnb.com | grep -i server`



```
(gimhani@kali)-[~]
$ curl -I https://www.airbnb.com | grep -i server
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total     Spent    Left     Speed
0         0     0      0      0      0      0  --:--:--   0:00:08 --:--:--  server: nginx
x-server-lifecycle-phase: running
0
x-server-name: www.airbnb.com
server-timing: cdn-cache; desc=MISS, edge; dur=243, origin; dur=551
```

Figure 2: Web server information for airbnb.com indicating the presence of an NGINX server as observed from HTTP response headers.

3. Weak TLS Cipher Suites

Technology: HTTPS / TLS Implementation (Port 443)

Vulnerability Description:

Weak or outdated TLS configurations, including deprecated cipher suites or older protocol versions (TLS 1.0/1.1, SSLv3), expose web applications to attacks like BEAST, POODLE, Sweet32 and MITM attacks. Lack of forward secrecy also allows past communications to be decrypted if private keys are compromised.

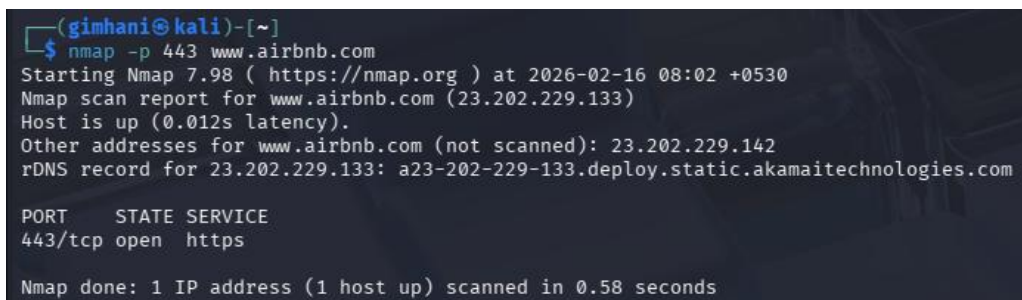
Criticality Level: Critical

Potential Impact:

- Man-in-the-middle attacks enabling session hijacking and credential theft
- Protocol downgrade attacks forcing use of vulnerable encryption
- Decryption of sensitive data including authentication tokens and personal information
- Compromise of past communications if private keys are exposed (without forward secrecy)
- Regulatory compliance violations (PCI DSS, HIPAA, GDPR requirements)

Command (Port Scan)

CODE: `nmap -p 443 airbnb.com`



```
(gimhani@kali)-[~]
$ nmap -p 443 www.airbnb.com
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-16 08:02 +0530
Nmap scan report for www.airbnb.com (23.202.229.133)
Host is up (0.012s latency).
Other addresses for www.airbnb.com (not scanned): 23.202.229.142
rDNS record for 23.202.229.133: a23-202-229-133.deploy.static.akamaitechnologies.com

PORT      STATE SERVICE
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 0.58 seconds
```

Figure 3: Nmap scan results confirming that HTTPS service is available on port 443 for airbnb.com.

CONCLUSION

The reconnaissance of Airbnb's web application using Kali Linux tools revealed an enterprise-grade infrastructure with Akamai CDN, NGINX web server, HTTPS/TLS encryption and robust security headers, indicating strong security practices. While no active exploitation was performed, potential risks such as CDN misconfiguration, weak NGINX settings and improper TLS configurations were identified, highlighting areas of concern. Key recommendations include maintaining strict CDN and WAF policies, hardening NGINX configurations, enforcing strong TLS protocols and cipher suites with forward secrecy, regularly reviewing security headers and conducting continuous monitoring and vulnerability assessments to ensure a strong security posture and protection against emerging threats.

REFERENCES

- [1] <https://nmap.org>
- [2] <https://nvd.nist.gov>
- [3] <https://hackerone.com>
- [4] <https://wappalyzer.com>